

Step 1:

Field	Value
Step	1
Module	SQL Injection
Hypothesis	ID parameter exploitable
Action	Manual SQLi payloads
Outcome	Partial / No escalation
Pivot	No
Notes	Observed filtering behavior; positive responses for some IDs

Step 2:

Field	Value
Step	2
Module	SQL Injection
Hypothesis	sqlmap may bypass filtering
Action	sqlmap (Grok-assisted syntax)
Outcome	Fail
Pivot	Yes
Notes	sqlmap reported parameter not injectable

Step 3:

Field	Value
Step	3
Module	Brute Force

Hypothesis	Weak credentials
Action	Hydra, Burp Intruder, ffuf
Outcome	Fail
Pivot	Yes
Notes	Ignored user-token logic; no successful login

Full dead end module.

Step 4:

Field	Value
Step	4
Module	LFI
Hypothesis	File traversal exposes hidden files
Action	../.. attempts +// bypass
Outcome	Partial
Pivot	No
Notes	Successfully bypassed filtering; no flag found

Step 5:

Field	Value
Step	5
Module	LFI
Hypothesis	Directory enumeration reveals target
Action	dirb scanning
Outcome	Fail
Pivot	Yes

Notes	No files discovered; LFI abandoned
-------	------------------------------------

Step 6:

Field	Value
Step	6
Module	File Upload
Hypothesis	Image upload can execute PHP
Action	Append PHP shell to image
Outcome	RCE
Pivot	No
Notes	<code>cmd=whoami</code> confirmed execution

Step 7:

Field	Value
Step	7
Module	Post-Exploitation
Hypothesis	Reverse shell improves control
Action	bash TCP reverse shell
Outcome	Success
Pivot	No
Notes	Interactive shell established

Step 8:

Field	Value
Step	8

Module	Post-Exploitation
Hypothesis	Flag in /hackable/flags
Action	cat, tail, less, strings
Outcome	Bait / Not real flag
Pivot	Yes
Notes	Strings worked but revealed decoy content

Step 9:

Field	Value
Step	9
Module	Post-Exploitation
Hypothesis	Flag in /var/www/html
Action	strings flag.txt
Outcome	Success
Pivot	No
Notes	Real flag retrieved

Metrics:

Total Steps = 9

Total Pivots = 4

Dead-End Modules = 3

Foothold Step = 6

Flag Step = 9

Exploit Chain Depth = 4

Success = Yes